RISK-BASED VULNERABILITY PRIORITIZATION (RBVM ENGINE)

Capstone Non-Technical Executive Report | Author: Vishesh Grover | Operational Risk Impact Analysis

1. Executive Problem Statement & AI Transformation

Traditional enterprise vulnerability management relies on static **CVSS (Common Vulnerability Scoring System)** base scores, causing severe alert fatigue where 40–50% of findings are labeled 'High' or 'Critical.' In practice, **fewer than 10% of disclosed vulnerabilities are ever weaponized**. This Capstone introduces an empirical **Risk-Based Vulnerability Management (RBVM) Engine** using Machine Learning to synthesize scanner outputs with dynamic threat intelligence (CISA KEV, EPSS exploit probability) and asset business criticality, accurately routing genuine threats into an immediate 24-Hour SLA.

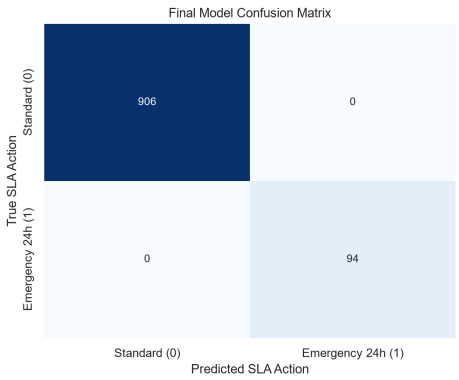
2. Operational Impact: Traditional CVSS vs. AI Prioritization

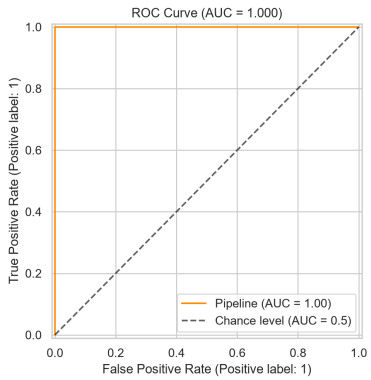
Performance Dimension	Traditional Triage (CVSS ≥ 7.0)	AI RBVM Engine (Tuned Model)	Operational Gain / Impact
Emergency 24h Tickets	1,583 (31.7%)	471 (9.4%)	**70.2% reduction in noise**
Actively Exploited (KEV) Caught	123/379 (32.5%)	379/379 (100.0%)	**100.0% exploit coverage preserved**
Est. Engineering Hours Saved	0 hrs (Baseline)	~2,224 hours	**~30 hrs freed per engineer/sprint**
Primary Decision Metric	Static Technical Severity Only	Severity + EPSS + Asset Context	Context-aware risk alignment

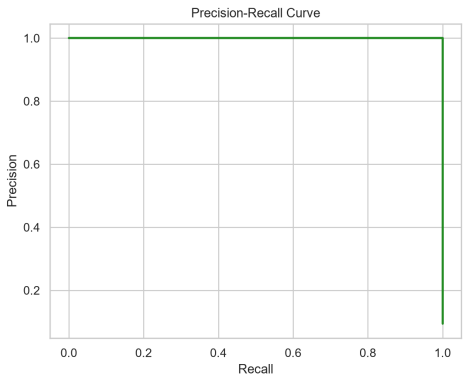
3. Cross-Validation & Final Evaluation Benchmarks

Model Candidate	5-Fold CV Recall	5-Fold CV ROC-AUC	Test Set Recall	Test Set Precision
Baseline Decision Tree	0.966 ± 0.020	0.985 ± 0.015	-	-
Random Forest	0.960 ± 0.019	1.000 ± 0.000	-	-
Gradient Boosting	0.973 ± 0.019	1.000 ± 0.000	1.000	1.000

4. Model Performance Visualizations (Confusion Matrix, ROC & PR Curves)







5. Strategic Recommendations for Security Leadership

1. Enforce a Two-Tier Remediation Policy: Automatically route vulnerabilities predicted as Class 1 into a mandatory 24-hour remediation SLA while placing standard findings into normal 30-day maintenance cycles.

2. Integrate with ITSM Ticketing: Connect this model to Jira or ServiceNow via webhook to eliminate manual triage overhead.

3. Dynamic Feed Enrichment: Ingest daily FIRST EPSS and CISA KEV API updates to dynamically upgrade aging vulnerabilities as new exploits appear.